



ZAP by
Checkmarx

ZAP by Checkmarx Scanning Report

Sites: <https://content-signature-2.cdn.mozilla.net> <http://172.31.1.95:3000>

Generated on Sun, 26 Jul 2026 17:38:00

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	1
Medium	2
Low	3
Informational	6
False Positives:	0

Alerts

Name	Risk Level	Number of Instances
SQL Injection	High	39
Content Security Policy (CSP) Header Not Set	Medium	Systemic
Vulnerable JS Library	Medium	1
Cookie without SameSite Attribute	Low	Systemic
Server Leaks Version Information via "Server" HTTP Response Header Field	Low	Systemic
X-Content-Type-Options Header Missing	Low	Systemic
Authentication Request Identified	Informational	1
Information Disclosure - Suspicious Comments	Informational	1
Modern Web Application	Informational	Systemic
Session Management Response Identified	Informational	20
User Agent Fuzzer	Informational	Systemic
User Controllable HTML Element Attribute (Potential XSS)	Informational	20

Alert Detail

High	SQL Injection
Description	SQL injection may be possible.

URL	http://172.31.1.95:3000/activity.atom?show_changesets=3-2
Node Name	http://172.31.1.95:3000/activity.atom (show_changesets)
Method	GET
Attack	3-2
Evidence	
Other Info	The original page results were successfully replicated using the expression [3-2] as the parameter value. The parameter value being modified was stripped from the HTML output for the purposes of the report.
URL	http://172.31.1.95:3000/activity.atom?show_changesets=3-2&show_documents=1&show_files=1&show_issues=1&show_messages=1&show_news=1&show_time_entries=1
Node Name	http://172.31.1.95:3000/activity.atom (show_changesets,show_documents,show_files,show_issues,show_messages,show_news,show_time_entries)
Method	GET
Attack	3-2
Evidence	
Other Info	The original page results were successfully replicated using the expression [3-2] as the parameter value. The parameter value being modified was stripped from the HTML output for the purposes of the report.
URL	http://172.31.1.95:3000/activity.atom?show_changesets=1&show_documents=2%2F2&show_files=1&show_issues=1&show_messages=1&show_news=1&show_time_entries=1
Node Name	http://172.31.1.95:3000/activity.atom (show_changesets,show_documents,show_files,show_issues,show_messages,show_news,show_time_entries)
Method	GET
Attack	2/2
Evidence	
Other Info	The original page results were successfully replicated using the expression [2/2] as the parameter value. The parameter value being modified was stripped from the HTML output for the purposes of the report.
URL	http://172.31.1.95:3000/activity.atom?show_changesets=1&show_documents=1&show_files=1&show_issues=1&show_messages=1&show_news=1&show_time_entries=1&show_wiki_edits=1
Node Name	http://172.31.1.95:3000/activity.atom (show_changesets,show_documents,show_files,show_issues,show_messages,show_news,show_time_entries,show_wiki_edits)
Method	GET
Attack	1 AND 1=1 --
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [1 AND 1=1 --] as the parameter value. The parameter value being modified was stripped from the HTML output for the purposes of the report. Data was returned for the original parameter. The vulnerability was detected by successfully restricting the data originally returned, by manipulating the boolean conditions.
URL	http://172.31.1.95:3000/activity.atom?show_changesets=1&show_documents=1&show_files=1&show_issues=1&show_messages=1&show_news=1&show_time_entries=1&show_wiki_edits=1&submit=Apply&utf8=%E2%9C%9C
Node Name	http://172.31.1.95:3000/activity.atom (show_changesets,show_documents,show_files,show_issues,show_messages,show_news,show_time_entries,show_wiki_edits,submit)
Method	GET
Attack	2/2
Evidence	

Other Info	The original page results were successfully replicated using the expression [2/2] as the parameter. The parameter value being modified was stripped from the HTML output for the purposes of the test.
URL	http://172.31.1.95:3000/activity.atom?show_changesets=1&show_documents=1&show_files=1&show_time_entries=1&show_wiki_edits=1&submit=Apply&utf8=%E2%9C%93
Node Name	http://172.31.1.95:3000/activity.atom (show_changesets,show_documents,show_files,show_issues)
Method	GET
Attack	1 AND 1=1 --
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [1 AND 1=1 --] and the parameter value being modified was stripped from the HTML output for the purposes of the test. Data was returned for the original parameter. The vulnerability was detected by successfully restricting the data originally returned, by manipulating the boolean conditions.
URL	http://172.31.1.95:3000/activity.atom?show_changesets=1&show_documents=1&show_files=1&show_time_entries=1&show_wiki_edits=1&submit=Apply&utf8=%E2%9C%93
Node Name	http://172.31.1.95:3000/activity.atom (show_changesets,show_documents,show_files,show_issues)
Method	GET
Attack	3-2
Evidence	
Other Info	The original page results were successfully replicated using the expression [3-2] as the parameter. The parameter value being modified was stripped from the HTML output for the purposes of the test.
URL	http://172.31.1.95:3000/activity.atom?show_changesets=1&show_documents=1&show_files=1&show_issues=1&show_messages=1&submit=Apply&utf8=%E2%9C%93
Node Name	http://172.31.1.95:3000/activity.atom (show_changesets,show_documents,show_files,show_issues)
Method	GET
Attack	3-2
Evidence	
Other Info	The original page results were successfully replicated using the expression [3-2] as the parameter. The parameter value being modified was stripped from the HTML output for the purposes of the test.
URL	http://172.31.1.95:3000/activity.atom?show_changesets=1&show_documents=1&show_files=1&show_issues=1&show_messages=1&submit=Apply&utf8=%E2%9C%93+AND+1%3D1+--+
Node Name	http://172.31.1.95:3000/activity.atom (show_changesets,show_documents,show_files,show_issues)
Method	GET
Attack	OR 1=1 --
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [AND 1=1 --] and the parameter value being modified was stripped from the HTML output for the purposes of the test. Data was NOT returned for the original parameter. The vulnerability was detected by successfully retrieving more data than originally returned, by manipulating the boolean conditions.

URL	http://172.31.1.95:3000/activity.atom?show_documents=3-2
Node Name	http://172.31.1.95:3000/activity.atom (show_documents)
Method	GET
Attack	3-2
Evidence	
Other Info	The original page results were successfully replicated using the expression [3-2] as the parameter value. The parameter value being modified was stripped from the HTML output for the purposes of the test.
URL	http://172.31.1.95:3000/activity.atom?show_files=3-2
Node Name	http://172.31.1.95:3000/activity.atom (show_files)
Method	GET
Attack	3-2
Evidence	
Other Info	The original page results were successfully replicated using the expression [3-2] as the parameter value. The parameter value being modified was stripped from the HTML output for the purposes of the test.
URL	http://172.31.1.95:3000/activity.atom?show_issues=3-2
Node Name	http://172.31.1.95:3000/activity.atom (show_issues)
Method	GET
Attack	3-2
Evidence	
Other Info	The original page results were successfully replicated using the expression [3-2] as the parameter value. The parameter value being modified was stripped from the HTML output for the purposes of the test.
URL	http://172.31.1.95:3000/activity.atom?show_messages=3-2
Node Name	http://172.31.1.95:3000/activity.atom (show_messages)
Method	GET
Attack	3-2
Evidence	
Other Info	The original page results were successfully replicated using the expression [3-2] as the parameter value. The parameter value being modified was stripped from the HTML output for the purposes of the test.
URL	http://172.31.1.95:3000/activity.atom?show_news=3-2
Node Name	http://172.31.1.95:3000/activity.atom (show_news)
Method	GET
Attack	3-2
Evidence	
Other Info	The original page results were successfully replicated using the expression [3-2] as the parameter value. The parameter value being modified was stripped from the HTML output for the purposes of the test.
URL	http://172.31.1.95:3000/activity.atom?show_time_entries=2%2F2
Node	

Name	http://172.31.1.95:3000/activity.atom (show_time_entries)
Method	GET
Attack	2/2
Evidence	
Other Info	The original page results were successfully replicated using the expression [2/2] as the parameter. The parameter value being modified was stripped from the HTML output for the purposes of the
URL	http://172.31.1.95:3000/activity.atom?show_wiki_edits=2%2F2
Node Name	http://172.31.1.95:3000/activity.atom (show_wiki_edits)
Method	GET
Attack	2/2
Evidence	
Other Info	The original page results were successfully replicated using the expression [2/2] as the parameter. The parameter value being modified was stripped from the HTML output for the purposes of the
URL	http://172.31.1.95:3000/issues.atom?available_columns%5B%5D=parent+AND+1%3D1+--+&c%5B%5D=estimated_hours&utf8=%E2%9C%93
Node Name	http://172.31.1.95:3000/issues.atom (available_columns[],c[],group_by,set_filter,t[],utf8)
Method	GET
Attack	parent AND 1=1 --
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [parent AND 1=1] The parameter value being modified was stripped from the HTML output for the purposes of the Data was returned for the original parameter. The vulnerability was detected by successfully restricting the data originally returned, by manipu
URL	http://172.31.1.95:3000/issues.atom?available_columns%5B%5D=parent&c%5B%5D=descripti%5B%5D=estimated_hours&utf8=%E2%9C%93
Node Name	http://172.31.1.95:3000/issues.atom (available_columns[],c[],group_by,set_filter,t[],utf8)
Method	GET
Attack	project OR 1=1 --
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [project AND 1=1] The parameter value being modified was stripped from the HTML output for the purposes of the Data was NOT returned for the original parameter. The vulnerability was detected by successfully retrieving more data than originally returned, by r
URL	http://172.31.1.95:3000/issues.atom?available_columns%5B%5D=parent&c%5B%5D=descripti%5B%5D=estimated_hours&utf8=%E2%9C%93+AND+1%3D1+--+
Node Name	http://172.31.1.95:3000/issues.atom (available_columns[],c[],group_by,set_filter,t[],utf8)
Method	GET
Attack	AND 1=1 --
Evidence	

Other Info	The page results were successfully manipulated using the boolean conditions [AND 1=1 --] and The parameter value being modified was stripped from the HTML output for the purposes of the Data was returned for the original parameter. The vulnerability was detected by successfully restricting the data originally returned, by manipu
URL	http://172.31.1.95:3000/issues.atom?c%5B%5D=project+AND+1%3D1+--+&c%5B%5D=tracker%5D=assigned_to&c%5B%5D=updated_on&f%5B%5D=description&f%5B%5D=due_date&f%5B%5Bdue_date%5D=%21*&op%5Bduplicates%5D=%21o&set_filter=1&t%5B%5D=&utf8=%E2%9
Node Name	http://172.31.1.95:3000/issues.atom (c[],c[],c[],c[],c[],c[],c[],f[],f[],f[],f[],group_by,op[description],o
Method	GET
Attack	project AND 1=1 --
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [project AND 1=1 The parameter value being modified was stripped from the HTML output for the purposes of the Data was returned for the original parameter. The vulnerability was detected by successfully restricting the data originally returned, by manipu
URL	http://172.31.1.95:3000/issues.atom?c%5B%5D=project&c%5B%5D=tracker+AND+1%3D1+--+5D=assigned_to&c%5B%5D=updated_on&f%5B%5D=description&f%5B%5D=due_date&f%5B%5Bdue_date%5D=%21*&op%5Bduplicates%5D=%21o&set_filter=1&t%5B%5D=&utf8=%E2%9
Node Name	http://172.31.1.95:3000/issues.atom (c[],c[],c[],c[],c[],c[],c[],f[],f[],f[],f[],group_by,op[description],o
Method	GET
Attack	tracker AND 1=1 --
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [tracker AND 1=1 The parameter value being modified was stripped from the HTML output for the purposes of the Data was returned for the original parameter. The vulnerability was detected by successfully restricting the data originally returned, by manipu
URL	http://172.31.1.95:3000/issues.atom?c%5B%5D=project&c%5B%5D=tracker&c%5B%5D=status%5D=updated_on&f%5B%5D=description+AND+1%3D1+--+&f%5B%5D=due_date&f%5B%5D=(%5Bdue_date%5D=%21*&op%5Bduplicates%5D=%21o&set_filter=1&t%5B%5D=&utf8=%E2%9
Node Name	http://172.31.1.95:3000/issues.atom (c[],c[],c[],c[],c[],c[],c[],f[],f[],f[],f[],group_by,op[description],o
Method	GET
Attack	description AND 1=1 --
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [description AND The parameter value being modified was stripped from the HTML output for the purposes of the Data was returned for the original parameter. The vulnerability was detected by successfully restricting the data originally returned, by manipu
URL	http://172.31.1.95:3000/issues.atom?c%5B%5D=project&c%5B%5D=tracker&c%5B%5D=status%5D=updated_on&f%5B%5D=description&f%5B%5D=due_date&f%5B%5D=duplicates+AND+1%3D1+--+&f%5B%5D=due_date%5D=%21*&op%5Bduplicates%5D=%21o&set_filter=1&t%5B%5D=&utf8=%E2%9

Node Name	http://172.31.1.95:3000/issues.atom (c[],c[],c[],c[],c[],c[],c[],f[],f[],f[],f[],group_by,op[description],o
Method	GET
Attack	duplicates AND 1=1 --
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [duplicates AND 1=1 --]. The parameter value being modified was stripped from the HTML output for the purposes of the test. Original Data was returned for the original parameter. The vulnerability was detected by successfully restricting the data originally returned, by manipulating the boolean conditions.
URL	http://172.31.1.95:3000/issues.atom?c%5B%5D=project&c%5B%5D=tracker&c%5B%5D=status&c%5B%5D=updated_on&f%5B%5D=description&f%5B%5D=due_date&f%5B%5D=duplicates&f%5B%5D=due_date%5D=%21*&op%5Bduplicates%5D=%21o&set_filter=1&t%5B%5D=&utf8=%E2%9C%9C
Node Name	http://172.31.1.95:3000/issues.atom (c[],c[],c[],c[],c[],c[],c[],f[],f[],f[],f[],group_by,op[description],o
Method	GET
Attack	AND 1=1 --
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [AND 1=1 --] and the parameter value being modified was stripped from the HTML output for the purposes of the test. Original Data was returned for the original parameter. The vulnerability was detected by successfully restricting the data originally returned, by manipulating the boolean conditions.
URL	http://172.31.1.95:3000/issues.atom?c%5B%5D=project&c%5B%5D=tracker&c%5B%5D=status&c%5B%5D=updated_on&f%5B%5D=description&f%5B%5D=due_date&f%5B%5D=duplicates&f%5B%5D=due_date%5D=%21*&op%5Bduplicates%5D=%21o&set_filter=1&t%5B%5D=&utf8=%E2%9C%9C
Node Name	http://172.31.1.95:3000/issues.atom (c[],c[],c[],c[],c[],c[],c[],f[],f[],f[],f[],group_by,op[description],o
Method	GET
Attack	OR 1=1 --
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [AND 1=1 --] and the parameter value being modified was stripped from the HTML output for the purposes of the test. Original Data was NOT returned for the original parameter. The vulnerability was detected by successfully retrieving more data than originally returned, by manipulating the boolean conditions.
URL	http://172.31.1.95:3000/issues.atom?c%5B%5D=project&c%5B%5D=tracker&c%5B%5D=status&c%5B%5D=updated_on&f%5B%5D=description&f%5B%5D=due_date&f%5B%5D=duplicates&f%5B%5D=due_date%5D=%21*&op%5Bduplicates%5D=%21o&set_filter=1+AND+1%3D1+--+&t%5B%5D=&utf8=%E2%9C%9C
Node Name	http://172.31.1.95:3000/issues.atom (c[],c[],c[],c[],c[],c[],c[],f[],f[],f[],f[],group_by,op[description],o
Method	GET
Attack	1 AND 1=1 --
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [1 AND 1=1 --] and the parameter value being modified was stripped from the HTML output for the purposes of the test. Original Data was NOT returned for the original parameter. The vulnerability was detected by successfully retrieving more data than originally returned, by manipulating the boolean conditions.

Info	Data was returned for the original parameter. The vulnerability was detected by successfully restricting the data originally returned, by manipu
URL	http://172.31.1.95:3000/issues.atom?c%5B%5D=project&c%5B%5D=tracker&c%5B%5D=status&c%5B%5D=updated_on&f%5B%5D=description&f%5B%5D=due_date&f%5B%5D=duplicates&f%5B%5D=assigned_to&op%5Bduplicates%5D=%21o&set_filter=1&t%5B%5D=&utf8=%E2%9C%93+AND+1%3D1
Node Name	http://172.31.1.95:3000/issues.atom (c[],c[],c[],c[],c[],c[],f[],f[],f[],f[],group_by,op[description],o
Method	GET
Attack	AND 1=1 --
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [AND 1=1 --] and The parameter value being modified was stripped from the HTML output for the purposes of the Data was returned for the original parameter. The vulnerability was detected by successfully restricting the data originally returned, by manipu
URL	http://172.31.1.95:3000/issues.atom?c%5B%5D=project&c%5B%5D=tracker&c%5B%5D=status&c%5B%5D=updated_on&f%5B%5D=description&f%5B%5D=due_date&f%5B%5D=duplicates&f%5B%5D=assigned_to&op%5Bduplicates%5D=%21o&set_filter=1&t%5B%5D=&utf8=%E2%9C%93&v%5Bdescription%5D=1
Node Name	http://172.31.1.95:3000/issues.atom (c[],c[],c[],c[],c[],c[],f[],f[],f[],f[],group_by,op[description],o
Method	GET
Attack	JtxVbGyc AND 1=1 --
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [JtxVbGyc AND 1 The parameter value being modified was stripped from the HTML output for the purposes of the Data was returned for the original parameter. The vulnerability was detected by successfully restricting the data originally returned, by manipu
URL	http://172.31.1.95:3000/issues.atom?c%5B%5D=project+AND+1%3D1+--+&c%5B%5D=tracker&c%5B%5D=assigned_to&c%5B%5D=updated_on&f%5B%5D=&group_by=&set_filter=1&t%5B%5D=&utf8=%E2%9C%93
Node Name	http://172.31.1.95:3000/issues.atom (c[],c[],c[],c[],c[],c[],f[],group_by,set_filter,t[],utf8)
Method	GET
Attack	project AND 1=1 --
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [project AND 1=1 The parameter value being modified was stripped from the HTML output for the purposes of the Data was returned for the original parameter. The vulnerability was detected by successfully restricting the data originally returned, by manipu
URL	http://172.31.1.95:3000/issues.atom?c%5B%5D=project&c%5B%5D=tracker&c%5B%5D=status&c%5B%5D=assigned_to&c%5B%5D=updated_on&f%5B%5D=&group_by=&set_filter=1&t%5B%5D=&utf8=%E2%9C%93
Node Name	http://172.31.1.95:3000/issues.atom (c[],c[],c[],c[],c[],c[],f[],group_by,set_filter,t[],utf8)
Method	GET
Attack	status OR 1=1 --

Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [status AND 1=1 --] The parameter value being modified was stripped from the HTML output for the purposes of the test. Data was NOT returned for the original parameter. The vulnerability was detected by successfully retrieving more data than originally returned, by manipulating the boolean conditions.
URL	http://172.31.1.95:3000/issues.atom?c%5B%5D=project&c%5B%5D=tracker&c%5B%5D=status&c%5B%5D=assigned_to&c%5B%5D=updated_on&f%5B%5D=&group_by=&set_filter=1&t%5B%5D=&utf8=%E2%9C%93
Node Name	http://172.31.1.95:3000/issues.atom (c[],c[],c[],c[],c[],c[],f[],group_by,set_filter,t[],utf8)
Method	GET
Attack	priority AND 1=1 --
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [priority AND 1=1 --] The parameter value being modified was stripped from the HTML output for the purposes of the test. Data was returned for the original parameter. The vulnerability was detected by successfully restricting the data originally returned, by manipulating the boolean conditions.
URL	http://172.31.1.95:3000/issues.atom?c%5B%5D=project&c%5B%5D=tracker&c%5B%5D=status&c%5B%5D=3D1+---+&c%5B%5D=updated_on&f%5B%5D=&group_by=&set_filter=1&t%5B%5D=&utf8=%E2%9C%93
Node Name	http://172.31.1.95:3000/issues.atom (c[],c[],c[],c[],c[],c[],c[],f[],group_by,set_filter,t[],utf8)
Method	GET
Attack	assigned_to AND 1=1 --
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [assigned_to AND 1=1 --] The parameter value being modified was stripped from the HTML output for the purposes of the test. Data was returned for the original parameter. The vulnerability was detected by successfully restricting the data originally returned, by manipulating the boolean conditions.
URL	http://172.31.1.95:3000/issues.atom?c%5B%5D=project&c%5B%5D=tracker&c%5B%5D=status&c%5B%5D=updated_on+AND+1%3D1+---+&f%5B%5D=&group_by=&set_filter=1&t%5B%5D=&utf8=%E2%9C%93
Node Name	http://172.31.1.95:3000/issues.atom (c[],c[],c[],c[],c[],c[],c[],f[],group_by,set_filter,t[],utf8)
Method	GET
Attack	updated_on AND 1=1 --
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [updated_on AND 1=1 --] The parameter value being modified was stripped from the HTML output for the purposes of the test. Data was returned for the original parameter. The vulnerability was detected by successfully restricting the data originally returned, by manipulating the boolean conditions.
URL	http://172.31.1.95:3000/issues.atom?c%5B%5D=project&c%5B%5D=tracker&c%5B%5D=status&c%5B%5D=updated_on&f%5B%5D=&group_by=+AND+1%3D1+---+&set_filter=1&t%5B%5D=&utf8=%E2%9C%93
Node Name	http://172.31.1.95:3000/issues.atom (c[],c[],c[],c[],c[],c[],c[],f[],group_by,set_filter,t[],utf8)

Method	GET
Attack	AND 1=1 --
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [AND 1=1 --] and The parameter value being modified was stripped from the HTML output for the purposes of the Data was returned for the original parameter. The vulnerability was detected by successfully restricting the data originally returned, by manipu
URL	http://172.31.1.95:3000/issues.atom?c%5B%5D=project&c%5B%5D=tracker&c%5B%5D=status&c%5B%5D=updated_on&f%5B%5D=&group_by=&set_filter=3-2&t%5B%5D=&utf8=%E2%9C%93
Node Name	http://172.31.1.95:3000/issues.atom (c[],c[],c[],c[],c[],c[],f[],group_by,set_filter,t[],utf8)
Method	GET
Attack	3-2
Evidence	
Other Info	The original page results were successfully replicated using the expression [3-2] as the paramet The parameter value being modified was stripped from the HTML output for the purposes of the
URL	http://172.31.1.95:3000/issues.pdf?available_columns%5B%5D=parent+AND+1%3D1+---+&c%5B%5D=estimated_hours&utf8=%E2%9C%93
Node Name	http://172.31.1.95:3000/issues.pdf (available_columns[],c[],group_by,set_filter,t[],utf8)
Method	GET
Attack	parent AND 1=1 --
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [parent AND 1=1 The parameter value being modified was stripped from the HTML output for the purposes of the Data was returned for the original parameter. The vulnerability was detected by successfully restricting the data originally returned, by manipu
URL	http://172.31.1.95:3000/issues.pdf?available_columns%5B%5D=parent&c%5B%5D=description&c%5B%5D=estimated_hours&utf8=%E2%9C%93
Node Name	http://172.31.1.95:3000/issues.pdf (available_columns[],c[],group_by,set_filter,t[],utf8)
Method	GET
Attack	description AND 1=1 --
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [description AND The parameter value being modified was stripped from the HTML output for the purposes of the Data was returned for the original parameter. The vulnerability was detected by successfully restricting the data originally returned, by manipu
URL	http://172.31.1.95:3000/issues.pdf?available_columns%5B%5D=parent&c%5B%5D=description&utf8=%E2%9C%93
Node Name	http://172.31.1.95:3000/issues.pdf (available_columns[],c[],group_by,set_filter,t[],utf8)
Method	GET

Attack	3-2
Evidence	
Other Info	The original page results were successfully replicated using the expression [3-2] as the parameter. The parameter value being modified was stripped from the HTML output for the purposes of the
URL	http://172.31.1.95:3000/issues.pdf?available_columns%5B%5D=parent&c%5B%5D=description93+AND+1%3D1+--+
Node Name	http://172.31.1.95:3000/issues.pdf (available_columns[],c[],group_by,set_filter,t[],utf8)
Method	GET
Attack	AND 1=1 --
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [AND 1=1 --] and The parameter value being modified was stripped from the HTML output for the purposes of the Data was returned for the original parameter. The vulnerability was detected by successfully restricting the data originally returned, by manipu
Instances	39
Solution	Do not trust client side input, even if there is client side validation in place. In general, type check all data on the server side. If the application uses JDBC, use PreparedStatement or CallableStatement, with parameters pa If the application uses ASP, use ADO Command Objects with strong type checking and parame If database Stored Procedures can be used, use them. Do *not* concatenate strings into queries in the stored procedure, or use 'exec', 'exec immediat Do not create dynamic SQL queries using simple string concatenation. Escape all data received from the client. Apply an 'allow list' of allowed characters, or a 'deny list' of disallowed characters in user input. Apply the principle of least privilege by using the least privileged database user possible. In particular, avoid using the 'sa' or 'db-owner' database users. This does not eliminate SQL inje Grant the minimum database access that is necessary for the application.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html
CWE Id	89
WASC Id	19
Plugin Id	40018

Medium	Content Security Policy (CSP) Header Not Set
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://172.31.1.95:3000

Node Name	http://172.31.1.95:3000
Method	GET
Attack	
Evidence	
Other Info	
URL	http://172.31.1.95:3000/
Node Name	http://172.31.1.95:3000/
Method	GET
Attack	
Evidence	
Other Info	
URL	http://172.31.1.95:3000/robots.txt
Node Name	http://172.31.1.95:3000/robots.txt
Method	GET
Attack	
Evidence	
Other Info	
URL	http://172.31.1.95:3000/search
Node Name	http://172.31.1.95:3000/search
Method	GET
Attack	
Evidence	
Other Info	
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038
Medium	Vulnerable JS Library
Description	The identified library appears to be vulnerable.

URL	http://172.31.1.95:3000/javascripts/jquery-1.11.1-ui-1.11.0-uj-3.1.4.js
Node Name	http://172.31.1.95:3000/javascripts/jquery-1.11.1-ui-1.11.0-uj-3.1.4.js
Method	GET
Attack	
Evidence	jquery-1.11.1-ui-1.11.0-uj-3.1.4.js
Other Info	The identified library jquery, version 1.11.1-ui-1.11.0-uj-3.1.4 is vulnerable. CVE-2020-11023 CVE-2015-9251 CVE-2019-11358 https://github.com/jquery/jquery/issues/2432 http://blog.jquery.com/2016/01/08/jquery-2-2-and-1-12-released/ http://research.insecurelabs.org/jquery/test/ https://blog.jquery.com/2019/04/10/jquery-3-4-0-released/ https://nvd.nist.gov/vuln/detail/CVE-2019-11358 https://github.com/advisories/GHSA-rmxg-73gg-4p98 https://nvd.nist.gov/vuln/detail/CVE-2015-9251 https://github.com/jquery/jquery/commit/753d591aea698e57d6db58c9f722cd0808619b1b https://bugs.jquery.com/ticket/11974 https://github.com/jquery/jquery.com/issues/162 https://blog.jquery.com/2020/04/10/jquery-3-5-0-released/
Instances	1
Solution	Upgrade to the latest version of the affected library.
Reference	https://owasp.org/Top10/A06_2021-Vulnerable_and_Outdated_Components/
CWE Id	1395
WASC Id	
Plugin Id	10003

Low	Cookie without SameSite Attribute
Description	A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks.
URL	http://172.31.1.95:3000
Node Name	http://172.31.1.95:3000
Method	GET
Attack	
Evidence	Set-Cookie: _redmine_session
Other Info	
URL	http://172.31.1.95:3000/

Node Name	http://172.31.1.95:3000/
Method	GET
Attack	
Evidence	Set-Cookie: _redmine_session
Other Info	
URL	http://172.31.1.95:3000/issues/gantt
Node Name	http://172.31.1.95:3000/issues/gantt
Method	GET
Attack	
Evidence	Set-Cookie: _redmine_session
Other Info	
URL	http://172.31.1.95:3000/projects
Node Name	http://172.31.1.95:3000/projects
Method	GET
Attack	
Evidence	Set-Cookie: _redmine_session
Other Info	
URL	http://172.31.1.95:3000/search
Node Name	http://172.31.1.95:3000/search
Method	GET
Attack	
Evidence	Set-Cookie: _redmine_session
Other Info	
Instances	Systemic
Solution	Ensure that the SameSite attribute is set to either 'lax' or ideally 'strict' for all cookies.
Reference	https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site
CWE Id	1275
WASC Id	13
Plugin Id	10054

Low	Server Leaks Version Information via "Server" HTTP Response Header Field
Description	The web/application server is leaking version information via the "Server" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your web/application server is subject to.
URL	http://172.31.1.95:3000/favicon.ico
Node Name	http://172.31.1.95:3000/favicon.ico
Method	GET

Attack	
Evidence	WEBrick/1.3.1 (Ruby/2.3.8/2018-10-18)
Other Info	
URL	http://172.31.1.95:3000/issues/gantt
Node Name	http://172.31.1.95:3000/issues/gantt
Method	GET
Attack	
Evidence	WEBrick/1.3.1 (Ruby/2.3.8/2018-10-18)
Other Info	
URL	http://172.31.1.95:3000/robots.txt
Node Name	http://172.31.1.95:3000/robots.txt
Method	GET
Attack	
Evidence	WEBrick/1.3.1 (Ruby/2.3.8/2018-10-18)
Other Info	
URL	http://172.31.1.95:3000/sitemap.xml
Node Name	http://172.31.1.95:3000/sitemap.xml
Method	GET
Attack	
Evidence	WEBrick/1.3.1 (Ruby/2.3.8/2018-10-18)
Other Info	
URL	http://172.31.1.95:3000/stylesheets/application.css
Node Name	http://172.31.1.95:3000/stylesheets/application.css
Method	GET
Attack	
Evidence	WEBrick/1.3.1 (Ruby/2.3.8/2018-10-18)
Other Info	
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to suppress the "Server" header or provide generic details.
Reference	https://httpd.apache.org/docs/current/mod/core.html#servertokens https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10) https://www.troyhunt.com/shhh-dont-let-your-response-headers/
CWE Id	497
WASC Id	13
Plugin Id	10036

Low

X-Content-Type-Options Header Missing

Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	http://172.31.1.95:3000/favicon.ico
Node Name	http://172.31.1.95:3000/favicon.ico
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://172.31.1.95:3000/javascripts/responsive.js
Node Name	http://172.31.1.95:3000/javascripts/responsive.js
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://172.31.1.95:3000/stylesheets/application.css
Node Name	http://172.31.1.95:3000/stylesheets/application.css
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://172.31.1.95:3000/stylesheets/jquery/jquery-ui-1.11.0.css
Node Name	http://172.31.1.95:3000/stylesheets/jquery/jquery-ui-1.11.0.css
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://172.31.1.95:3000/stylesheets/responsive.css

Node Name	http://172.31.1.95:3000/stylesheets/responsive.css
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	Systemic
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application /web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security_Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational	Authentication Request Identified
Description	The given request has been identified as an authentication request. The 'Other Info' field contains a set of key=value lines which identify any relevant fields. If the request is in a context which has an Authentication Method set to "Auto-Detect" then this rule will change the authentication to match the request identified.
URL	http://172.31.1.95:3000/login
Node Name	http://172.31.1.95:3000/login ()(authenticity_token,back_url,login,password,username,utf8)
Method	POST
Attack	
Evidence	password
Other Info	userParam=login userValue=Login » passwordParam=password referer=http://172.31.1.95:3000/login csrfToken=authenticity_token
Instances	1
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/
CWE Id	
WASC Id	
Plugin Id	10111

Informational	Information Disclosure - Suspicious Comments
Description	The response appears to contain suspicious comments which may help an attacker.

URL	http://172.31.1.95:3000/javascripts/context_menu.js
Node Name	http://172.31.1.95:3000/javascripts/context_menu.js
Method	GET
Attack	
Evidence	// TODO
Other Info	The following pattern was used: \bTODO\b and was detected in likely comment: "// TODO", see evidence field for the suspicious comment/snippet.
Instances	1
Solution	Remove all comments that return information that may help an attacker and fix any underlying problems they refer to.
Reference	
CWE Id	615
WASC Id	13
Plugin Id	10027

Informational	Modern Web Application
Description	The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.
URL	http://172.31.1.95:3000
Node Name	http://172.31.1.95:3000
Method	GET
Attack	
Evidence	
Other Info	Links have been found that do not have traditional href attributes, which is an indication that this is a modern web application.
URL	http://172.31.1.95:3000/
Node Name	http://172.31.1.95:3000/
Method	GET
Attack	
Evidence	
Other Info	Links have been found that do not have traditional href attributes, which is an indication that this is a modern web application.
URL	http://172.31.1.95:3000/account/register
Node Name	http://172.31.1.95:3000/account/register
Method	GET
Attack	
Evidence	
Other Info	Links have been found that do not have traditional href attributes, which is an indication that this is a modern web application.
URL	http://172.31.1.95:3000/activity
Node Name	http://172.31.1.95:3000/activity

Method	GET
Attack	
Evidence	
Other Info	Links have been found that do not have traditional href attributes, which is an indication that this is a modern web application.
URL	http://172.31.1.95:3000/projects
Node Name	http://172.31.1.95:3000/projects
Method	GET
Attack	
Evidence	
Other Info	Links have been found that do not have traditional href attributes, which is an indication that this is a modern web application.
Instances	Systemic
Solution	This is an informational alert and so no changes are required.
Reference	
CWE Id	
WASC Id	
Plugin Id	10109

Informational	Session Management Response Identified
Description	The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.
URL	http://172.31.1.95:3000
Node Name	http://172.31.1.95:3000
Method	GET
Attack	
Evidence	_redmine_session
Other Info	cookie:_redmine_session
URL	http://172.31.1.95:3000/
Node Name	http://172.31.1.95:3000/
Method	GET
Attack	
Evidence	_redmine_session
Other Info	cookie:_redmine_session
URL	http://172.31.1.95:3000/account/lost_password
Node Name	http://172.31.1.95:3000/account/lost_password
Method	GET
Attack	

Evidence	_redmine_session
Other Info	cookie:_redmine_session
URL	http://172.31.1.95:3000/account/register
Node Name	http://172.31.1.95:3000/account/register
Method	GET
Attack	
Evidence	_redmine_session
Other Info	cookie:_redmine_session
URL	http://172.31.1.95:3000/activity
Node Name	http://172.31.1.95:3000/activity
Method	GET
Attack	
Evidence	_redmine_session
Other Info	cookie:_redmine_session
URL	http://172.31.1.95:3000/activity?from=2026-06-26
Node Name	http://172.31.1.95:3000/activity (from)
Method	GET
Attack	
Evidence	_redmine_session
Other Info	cookie:_redmine_session
URL	http://172.31.1.95:3000/activity?show_changesets=1
Node Name	http://172.31.1.95:3000/activity (show_changesets)
Method	GET
Attack	
Evidence	_redmine_session
Other Info	cookie:_redmine_session
URL	http://172.31.1.95:3000/activity?show_documents=1
Node Name	http://172.31.1.95:3000/activity (show_documents)
Method	GET
Attack	
Evidence	_redmine_session
Other Info	cookie:_redmine_session
URL	http://172.31.1.95:3000/activity?show_issues=1
Node	

Name	http://172.31.1.95:3000/activity (show_issues)
Method	GET
Attack	
Evidence	_redmine_session
Other Info	cookie:_redmine_session
URL	http://172.31.1.95:3000/activity?show_messages=1
Node Name	http://172.31.1.95:3000/activity (show_messages)
Method	GET
Attack	
Evidence	_redmine_session
Other Info	cookie:_redmine_session
URL	http://172.31.1.95:3000/activity?show_news=1
Node Name	http://172.31.1.95:3000/activity (show_news)
Method	GET
Attack	
Evidence	_redmine_session
Other Info	cookie:_redmine_session
URL	http://172.31.1.95:3000/activity.atom
Node Name	http://172.31.1.95:3000/activity.atom
Method	GET
Attack	
Evidence	_redmine_session
Other Info	cookie:_redmine_session
URL	http://172.31.1.95:3000/issues/calendar
Node Name	http://172.31.1.95:3000/issues/calendar
Method	GET
Attack	
Evidence	_redmine_session
Other Info	cookie:_redmine_session
URL	http://172.31.1.95:3000/login
Node Name	http://172.31.1.95:3000/login
Method	GET
Attack	
Evidence	_redmine_session
Other	

Info	cookie:_redmine_session
URL	http://172.31.1.95:3000/login?back_url=http%3A%2F%2F172.31.1.95%3A3000%2Fissues%2Fgantt
Node Name	http://172.31.1.95:3000/login (back_url)
Method	GET
Attack	
Evidence	_redmine_session
Other Info	cookie:_redmine_session
URL	http://172.31.1.95:3000/news.atom
Node Name	http://172.31.1.95:3000/news.atom
Method	GET
Attack	
Evidence	_redmine_session
Other Info	cookie:_redmine_session
URL	http://172.31.1.95:3000/projects
Node Name	http://172.31.1.95:3000/projects
Method	GET
Attack	
Evidence	_redmine_session
Other Info	cookie:_redmine_session
URL	http://172.31.1.95:3000/search
Node Name	http://172.31.1.95:3000/search
Method	GET
Attack	
Evidence	_redmine_session
Other Info	cookie:_redmine_session
URL	http://172.31.1.95:3000/search?q=ZAP&utf8=%E2%9C%93
Node Name	http://172.31.1.95:3000/search (q,utf8)
Method	GET
Attack	
Evidence	_redmine_session
Other Info	cookie:_redmine_session
URL	http://172.31.1.95:3000/account/register
Node Name	http://172.31.1.95:3000/account/register ()(authenticity_token,commit,pref[hide_mail],user[firstname],user[language],user[lastname],user[login],user[mail],user[password],user[password_confirmation],utf8)

Method	POST
Attack	
Evidence	_redmine_session
Other Info	cookie:_redmine_session
Instances	20
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/
CWE Id	
WASC Id	
Plugin Id	10112

Informational	User Agent Fuzzer
Description	Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as a Search Engine Crawler). Compares the response statuscode and the hashcode of the response body with the original response.
URL	http://172.31.1.95:3000
Node Name	http://172.31.1.95:3000
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
URL	http://172.31.1.95:3000/
Node Name	http://172.31.1.95:3000/
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
URL	http://172.31.1.95:3000/account/lost_password
Node Name	http://172.31.1.95:3000/account/lost_password ()(authenticity_token,commit,mail,utf8)
Method	POST
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
Instances	Systemic
Solution	
Reference	https://owasp.org/wstg
CWE Id	
WASC Id	
Plugin Id	10104

Informational	User Controllable HTML Element Attribute (Potential XSS)
Description	This check looks at user-supplied input in query string parameters and POST data to identify what detection for XSS (cross-site scripting) that will require further review by a security analyst to de
URL	http://172.31.1.95:3000/activity?from=2026-06-26
Node Name	http://172.31.1.95:3000/activity (from)
Method	GET
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS http://172.31.1.95:3000/activity?from=2026-06-26 appears to include user input in: a(n) [input] tag [value] attribute The user input found was: from=2026-06-26 The user-controlled value was: 2026-06-26
URL	http://172.31.1.95:3000/activity?show_changesets=1
Node Name	http://172.31.1.95:3000/activity (show_changesets)
Method	GET
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS http://172.31.1.95:3000/activity?show_changesets=1 appears to include user input in: a(n) [meta] tag [content] attribute The user input found was: show_changesets=1 The user-controlled value was: width=device-width, initial-scale=1, maximum-scale=1, user-scalable=no
URL	http://172.31.1.95:3000/activity?show_changesets=1&show_documents=1&show_files=1&show_issues=1&show_messages=1&E2%9C%93
Node Name	http://172.31.1.95:3000/activity (show_changesets,show_documents,show_files,show_issues,sl
Method	GET
Attack	
Evidence	
	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS

Other Info	http://172.31.1.95:3000/activity?show_changesets=1&show_documents=1&show_files=1&show_issues=1&show_messages=1&E2%9C%93 appears to include user input in: a(n) [meta] tag [content] attribute The user input found was: show_changesets=1 The user-controlled value was: width=device-width, initial-scale=1, maximum-scale=1, user-scalable=no
URL	http://172.31.1.95:3000/activity?show_changesets=1&show_documents=1&show_files=1&show_issues=1&show_messages=1&E2%9C%93
Node Name	http://172.31.1.95:3000/activity (show_changesets,show_documents,show_files,show_issues,sl
Method	GET
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS http://172.31.1.95:3000/activity?show_changesets=1&show_documents=1&show_files=1&show_issues=1&show_messages=1&E2%9C%93 appears to include user input in: a(n) [input] tag [value] attribute The user input found was: submit=Apply The user-controlled value was: apply
URL	http://172.31.1.95:3000/activity?show_documents=1
Node Name	http://172.31.1.95:3000/activity (show_documents)
Method	GET
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS http://172.31.1.95:3000/activity?show_documents=1 appears to include user input in: a(n) [meta] tag [content] attribute The user input found was: show_documents=1 The user-controlled value was:

	width=device-width, initial-scale=1, maximum-scale=1, user-scalable=no
URL	http://172.31.1.95:3000/activity?show_files=1
Node Name	http://172.31.1.95:3000/activity (show_files)
Method	GET
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS http://172.31.1.95:3000/activity?show_files=1 appears to include user input in: a(n) [meta] tag [content] attribute The user input found was: show_files=1 The user-controlled value was: width=device-width, initial-scale=1, maximum-scale=1, user-scalable=no
URL	http://172.31.1.95:3000/activity?show_issues=1
Node Name	http://172.31.1.95:3000/activity (show_issues)
Method	GET
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS http://172.31.1.95:3000/activity?show_issues=1 appears to include user input in: a(n) [meta] tag [content] attribute The user input found was: show_issues=1 The user-controlled value was: width=device-width, initial-scale=1, maximum-scale=1, user-scalable=no
URL	http://172.31.1.95:3000/activity?show_messages=1
Node Name	http://172.31.1.95:3000/activity (show_messages)
Method	GET
Attack	
Evidence	
	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS http://172.31.1.95:3000/activity?show_messages=1 appears to include user input in: a(n) [meta] tag [content] attribute

Other Info	The user input found was: show_messages=1 The user-controlled value was: width=device-width, initial-scale=1, maximum-scale=1, user-scalable=no
URL	http://172.31.1.95:3000/activity?show_news=1
Node Name	http://172.31.1.95:3000/activity (show_news)
Method	GET
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS http://172.31.1.95:3000/activity?show_news=1 appears to include user input in: a(n) [meta] tag [content] attribute The user input found was: show_news=1 The user-controlled value was: width=device-width, initial-scale=1, maximum-scale=1, user-scalable=no
URL	http://172.31.1.95:3000/activity?show_wiki_edits=1
Node Name	http://172.31.1.95:3000/activity (show_wiki_edits)
Method	GET
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS http://172.31.1.95:3000/activity?show_wiki_edits=1 appears to include user input in: a(n) [meta] tag [content] attribute The user input found was: show_wiki_edits=1 The user-controlled value was: width=device-width, initial-scale=1, maximum-scale=1, user-scalable=no
URL	http://172.31.1.95:3000/login?back_url=http%3A%2F%2F172.31.1.95%3A3000%2Fissues%2F
Node Name	http://172.31.1.95:3000/login (back_url)
Method	GET
Attack	
Evidence	

Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS http://172.31.1.95:3000/login?back_url=http%3A%2F%2F172.31.1.95%3A3000%2Fissues%2F appears to include user input in: a(n) [input] tag [value] attribute The user input found was: back_url=http://172.31.1.95:3000/issues/gantt The user-controlled value was: http://172.31.1.95:3000/issues/gantt
URL	http://172.31.1.95:3000/search?q=ZAP&utf8=%E2%9C%93
Node Name	http://172.31.1.95:3000/search (q,utf8)
Method	GET
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS http://172.31.1.95:3000/search?q=ZAP&utf8=%E2%9C%93 appears to include user input in: a(n) [input] tag [value] attribute The user input found was: q=ZAP The user-controlled value was: zap
URL	http://172.31.1.95:3000/account/register
Node Name	http://172.31.1.95:3000/account/register ()(authenticity_token,commit,pref[hide_mail],user[firstnam
Method	POST
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS http://172.31.1.95:3000/account/register appears to include user input in: a(n) [input] tag [type] attribute The user input found was: commit=Submit The user-controlled value was: submit
URL	http://172.31.1.95:3000/account/register
Node	http://172.31.1.95:3000/account/register ()(authenticity_token,commit,pref[hide_mail],user[firstnam

Name	[password_confirmation],utf8)
Method	POST
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS http://172.31.1.95:3000/account/register appears to include user input in: a(n) [input] tag [value] attribute The user input found was: user[firstname]=ZAP The user-controlled value was: zap
URL	http://172.31.1.95:3000/account/register
Node Name	http://172.31.1.95:3000/account/register ()(authenticity_token,commit,pref[hide_mail],user[firstname],[password_confirmation],utf8)
Method	POST
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS http://172.31.1.95:3000/account/register appears to include user input in: a(n) [html] tag [lang] attribute The user input found was: user[language]=en The user-controlled value was: en
URL	http://172.31.1.95:3000/account/register
Node Name	http://172.31.1.95:3000/account/register ()(authenticity_token,commit,pref[hide_mail],user[firstname],[password_confirmation],utf8)
Method	POST
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS http://172.31.1.95:3000/account/register appears to include user input in: a(n) [input] tag [value] attribute The user input found was: user[lastname]=ZAP

	The user-controlled value was: zap
URL	http://172.31.1.95:3000/account/register
Node Name	http://172.31.1.95:3000/account/register ()(authenticity_token,commit,pref[hide_mail],user[firstnam[password_confirmation],utf8)
Method	POST
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS http://172.31.1.95:3000/account/register appears to include user input in: a(n) [input] tag [value] attribute The user input found was: user[login]=ZAP The user-controlled value was: zap
URL	http://172.31.1.95:3000/account/register
Node Name	http://172.31.1.95:3000/account/register ()(authenticity_token,commit,pref[hide_mail],user[firstnam[password_confirmation],utf8)
Method	POST
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS http://172.31.1.95:3000/account/register appears to include user input in: a(n) [input] tag [value] attribute The user input found was: user[mail]=ZAP The user-controlled value was: zap
URL	http://172.31.1.95:3000/account/register
Node Name	http://172.31.1.95:3000/account/register ()(authenticity_token,commit,pref[hide_mail],user[firstnam[password_confirmation],utf8)
Method	POST
Attack	
Evidence	
	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS http://172.31.1.95:3000/account/register

Other Info	appears to include user input in: a(n) [input] tag [value] attribute The user input found was: user[password]=ZAP The user-controlled value was: zap
URL	http://172.31.1.95:3000/account/register
Node Name	http://172.31.1.95:3000/account/register ()(authenticity_token,commit,pref[hide_mail],user[firstn: [password_confirmation],utf8)
Method	POST
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS http://172.31.1.95:3000/account/register appears to include user input in: a(n) [input] tag [value] attribute The user input found was: user[password_confirmation]=ZAP The user-controlled value was: zap
Instances	20
Solution	Validate all input and sanitize output it before writing to any HTML attributes.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html
CWE Id	20
WASC Id	20
Plugin Id	10031